

Absolutely! Here's a **Security Architectural Pattern and Implementation Guidelines** document specifically for evaluating **third-party vendors (SaaS and On-Premises) offering AI/LLM capabilities**, aligned with **Third-Party Risk Management (TPRM)** principles and using your previously established format.

---

**Name**

**Third-Party AI/LLM Vendor Evaluation (SaaS and On-Premises)**

---

**Status**

**PUBLISHED**

---

**Last Revision Date**

**26 May 2025**

---

**Description**

This pattern defines security and architectural practices for assessing third-party vendors that provide AI/LLM features either via **SaaS offerings** or **on-premises deployments**. The goal is to ensure that such vendors align with enterprise security, privacy, and responsible AI standards as part of the Third-Party Risk Management (TPRM) lifecycle.

---

**Threat Modeling**

| Threat Category      | Example Risks                                                           |
|----------------------|-------------------------------------------------------------------------|
| Data Privacy         | Sensitive or regulated data may be exposed or retained without consent  |
| Model Abuse          | LLMs may generate harmful, biased, or misleading outputs                |
| Data Leakage         | Prompts or responses may be logged, cached, or reused by vendor systems |
| Integration Risk     | SaaS APIs or on-prem connectors may introduce vulnerabilities           |
| Compliance Violation | Use of AI may conflict with regulations (GDPR, HIPAA, etc.)             |

| Threat Category   | Example Risks                                                          |
|-------------------|------------------------------------------------------------------------|
| Inconsistent SLAs | Vendor reliability, latency, or support may impact business operations |
| Shadow AI         | Unauthorized AI services bypass security review processes              |

---

## Security Controls

### Common Controls (SaaS & On-Premises)

1. **TPRM Intake and Classification**
    - Enforce intake through a standardized vendor security assessment process.
    - Classify AI/LLM vendors as “High Risk” if they process sensitive data or use generative AI.
  2. **Data Protection and Privacy**
    - Require a **Data Processing Agreement (DPA)** aligned with company privacy policies.
    - Enforce data minimization and masking practices where applicable.
    - Validate opt-in/out for model fine-tuning or data reuse.
  3. **Responsible AI and Model Governance**
    - Demand disclosure of:
      - Model type (e.g., GPT, Claude, local LLM)
      - Prompt retention policies
      - Output safety and moderation mechanisms
    - Require documented bias mitigation and explainability capabilities.
  4. **Security Architecture Review**
    - Review:
      - API design and authentication flows
      - Encryption in transit and at rest (TLS 1.2+/AES-256)
      - Isolation of tenant data (SaaS) or sandboxing (On-prem)
      - Identity and access control policies
- 

### SaaS-Specific Controls

5. **API Key Management**
  - Require API credentials to be stored in enterprise secret managers.
  - Ensure access is least-privilege and auditable.
6. **Third-Party Logging and Monitoring**
  - Validate availability of audit logs for prompt/response activity.
  - Confirm vendor has internal monitoring, alerting, and threat detection.
7. **Cloud Security Certifications**
  - Require **SOC 2 Type II, ISO 27001**, or similar.
  - Assess AI-specific compliance (e.g., EU AI Act, NIST AI RMF alignment).

---

## On-Premises-Specific Controls

8. **Secure Deployment Model**
    - Require deployment in a **segmented VPC** or air-gapped zone.
    - Prefer containerized or VM-based installs with no outbound network access.
  9. **Model Artifact Inspection**
    - Scan AI binaries or model weights for tampering or backdoors.
    - Verify signed packages and secure supply chain.
  10. **Patch and Upgrade Policy**
    - Require vendor to support timely updates for security patches and vulnerability disclosures.
    - Integrate into enterprise patching cadence.
- 

## Implementation Guidance

1. **Evaluate Vendor Policies**
    - Review AI Acceptable Use Policy, retention policy, and incident handling procedures.
    - Check whether vendor offers audit trails for AI decisions or outputs.
  2. **Pilot with Red Teaming**
    - Test vendor LLMs with adversarial prompts and simulated abuse scenarios.
    - Evaluate response safety, rate limiting, and error handling.
  3. **Escrow and Exit Strategy**
    - For on-prem deployments, require **source code or escrow agreements** if business-critical.
    - Ensure clear data export, model retirement, and de-integration plans.
  4. **Cross-Functional Review**
    - Involve Security, Privacy, Legal, and Engineering teams in the review cycle.
    - Create a risk register for tracking unresolved or deferred controls.
- 

## Testing and Validation

| Area                | Test Method                                                                    |
|---------------------|--------------------------------------------------------------------------------|
| Security Validation | Vulnerability scanning, DAST/SAST on integrations, penetration testing         |
| Privacy Assurance   | Inject test data and verify no unauthorized logging or training                |
| Output Validation   | Hallucination testing, content moderation checks, prompt injection simulations |

| Area                            | Test Method                                                                      |
|---------------------------------|----------------------------------------------------------------------------------|
| <b>Model Behavior Logs</b>      | Validate access to output logs, scoring, and versioned prompt-response histories |
| <b>Auditability</b>             | Ensure vendor provides full audit logs for prompt/response and admin actions     |
| <b>Uptime &amp; SLA Testing</b> | Validate failover support, rate limits, and monitoring dashboard accessibility   |

---

Let me know if you'd like:

- A **vendor scorecard template**
- A **PDF/Word export**
- A **checklist for procurement/security teams**
- Or integration into a GRC tool like OneTrust, ServiceNow, or Archer.